



Auditoría Completa

Wallet Control — pre-testers / pre-lanzamiento público

Generado el **15 de julio de 2026**

Metodología: **AUDITA** (técnico/funcional/seguridad) + **ESTETIK** (visual/UX, revisión de código) + checklist
QA **FIXA**

Diagnóstico real ejecutado: npm outdated · npm audit · expo-doctor · tsc --noEmit · eas whoami · eas build:list

Resumen ejecutivo

Listo para testers cerrados

~88%

Listo para público general (Play Store)

~55%

El bloqueante que aparecía como más crítico en el informe anterior (7 de julio) — **EAS nunca vinculado** — ya no existe. Se confirmó con `eas whoami` y `eas build:list` que la cuenta está vinculada y hay **2 builds terminados**, el más reciente del mismo 15 de julio (13:47), con APK real descargable.

Se verificó que los 3 commits posteriores a ese build no tocan código de la app (uno pertenece a otro proyecto, otro es un archivo vacío suelto, otro son solo notas) — el APK de hoy refleja el código real actual. No hace falta rebuildear para enviarlo a testers.

🚫 Bloqueantes para público general

No bloquean el envío a testers cerrados.

Hallazgo	Por qué importa	Prioridad
Política de privacidad no publicada	Sigue sin existir ni como archivo ni como URL pública (solo hay microcopy en onboarding y una FAQ en el manual PDF, que no es un documento legal). Requisito obligatorio para el Data Safety form de Play Store y para la Ley 1581/2012 de Colombia (Habeas Data), ya que se manejan email y datos financieros personales.	Alta
"Confirm email" desactivado en Supabase	Desactivado a propósito según <code>NOTAS/ajustes wallet-control1.txt</code> . El código ya está listo desde el 6 de julio — falta solo el toggle en el dashboard (Authentication → Providers → Email). Sin esto, cualquiera se registra con un email inventado.	Alta
Trámites de Play Store	Cuenta de desarrollador de Google Play, ficha de clasificación de contenido, screenshots reales — administrativo, no técnico.	Media

🔒 Seguridad

Hallazgo	Detalle	Prioridad
Sin rate limiting en el proxy de IA	Sí exige un JWT válido de un usuario autenticado (<code>lib/claude.ts</code> envía <code>Authorization: Bearer session.access_token</code> , Supabase lo verifica en el gateway)	Media-Alta

(<code>supabase/functions/claude-proxy</code>)	— no es un proxy abierto a cualquiera en internet. Pero cualquier cuenta registrada (trivial mientras Confirm email esté off) puede llamarlo sin límite y generar costo ilimitado en la API de Anthropic.	
Enumeración de cuentas vía <code>get_email_by_nickname</code>	El RPC de login por username permite averiguar si un nickname existe y obtener su email, sin rate limiting. Diseño acotado (no expone el resto del perfil) pero es superficie de enumeración.	Baja
Sin secrets hardcodeados	<code>.env</code> fuera de git (confirmado con <code>git ls-files</code>), key de Anthropic vive solo server-side, RLS correcto en <code>profiles</code> (select/insert/update solo del propio registro).	✓ Resuelto
<code>npm audit</code> : 17 vulnerabilidades moderadas	Todas en dependencias de build-time de Expo (js-yaml, postcss, uuid). No afectan el runtime de la app instalada — riesgo de toolchain, no de producto.	Baja

Bugs

No se encontraron bugs funcionales nuevos: `tsc --noEmit` limpio, `expo-doctor` solo marca un desajuste de parche menor (`expo 54.0.35` instalado vs `54.0.36` esperado — fix: `npx expo install --check`). El historial de FIXA muestra los bugs conocidos (caché de Metro, ThemeProvider, pantalla en blanco, notificaciones) ya resueltos.

Para eliminar

- `APPS/wallet-control/Nuevo Documento de texto.txt` — archivo vacío suelto que entró sin querer en el commit de auto-sync de hoy, probablemente creado desde el explorador de Windows.
- `assets/fonts/SpaceMono-Regular.ttf` sigue siendo la fuente default del template de Expo Router, nunca reemplazada por tipografía de marca.

Visual / UX — re-verificación de los 6 hallazgos de ESTETIK (09-jul)

Limitación de esta pasada: no se logró conectar `mobile-mcp` en esta sesión (el servidor está bien configurado y con permisos ya aprobados de sesiones previas, pero no arrancó). Esta sección se hizo por revisión de código, no viendo la app renderizada en el emulador. Se recomienda repetir un pase visual en vivo (IMAGINA o ESTETIK completo) antes de repartir el APK.

Hallazgo original	Estado ahora
-------------------	--------------

Centralizar SPACING/RADIUS (faltaban en theme.ts)	Parcial — los tokens ya existen en <code>constants/theme.ts</code> , pero tienen 0 usos reales en <code>app/</code> . Se construyó la solución y nunca se migró el código.
Extraer <code>BottomSheet</code> reutilizable (duplicado en 6+ archivos)	Mayormente resuelto — <code>components/BottomSheet.tsx</code> existe y lo usan 3 modales. Quedan <code>CardFormModal.tsx</code> y <code>CategoryFormModal.tsx</code> sin migrar.
Proteger montos de corte de texto	✓ Resuelto — presente en los 3 archivos señalados y extendido a 5 más.
Botones solo-ícono sin <code>accessibilityLabel</code>	Mayormente resuelto — subió de 32 a 44 ocurrencias (11→14 archivos), cubriendo tarjetas/búsqueda/perfil.
Loaders faltantes en Tarjetas y chat de Finando	✓ Resuelto — <code>ActivityIndicator</code> presente en ambos.
Hex sueltos sin unificar	Abierto, bajo impacto — 30 ocurrencias, 26 son del HTML del manual PDF (contexto aparte), solo 4 reales en pantallas de la app.

✓ Lo que ya funciona bien

- Auth sólido: sesión persistida + `autoRefreshToken`, RLS correcto, sync de perfil local↔Supabase, redirect a onboarding en logout.
- Arquitectura de IA correcta: la key de Anthropic nunca toca el cliente.
- `tsc --noEmit` limpio, cero `console.log` en el código fuente.
- Ícono y splash propios, bundle identifiers configurados, EAS build funcionando end-to-end.
- Helper de responsive (`useResponsive` / `scaledSheet`) implementado tal como pedía la lección de `receta-apps.txt`.
- Validación de formularios razonable en onboarding (regex de email, medidor de fuerza de contraseña, longitudes mínimas).

Antes de enviar a testers hoy: el APK actual (build de hoy, 13:47) ya sirve tal cual — no hay bloqueante técnico. La prioridad más útil antes de ese envío sería agregar un tope básico al proxy de IA (aunque sea un límite diario simple por usuario), porque testers activos usando el chat de Finando sin límite ya es costo real.

Auditoría generada con AUDITA + ESTETIK + checklist FIXA sobre APPS/wallet-control. Ningún archivo del proyecto fue modificado durante este proceso.